Container security checklist for developers on OpenShift

Score your team: tick what is true today. Each row is a practice from the workshop, with the DORA article it supports.

	Practice	Where you did it	DORA article (working mapping)
☐	App is stateless, config in environment, port-bound, logs to stdout as JSON	Steps 1, 2 (`01-12factor-platform/main.go`)	Art. 10 (detection; logging detail is in the technical standards)
☐	Base images are Red Hat UBI (or Hardened Images), versioned, ideally pinned by digest	Step 2 (`02-secure-images/Containerfile.secure`)	Art. 28 (third-party ICT risk)
☐	Multi-stage build: no toolchain, no source in the runtime image	Step 2	Art. 9 (protection and prevention)
☐	Container runs as non-root and is SCC-ready (`USER 1001`, group `0` ownership)	Steps 2, 3	Art. 9
☐	Root and privileged manifests are refused by admission; nobody holds a standing exemption	Step 3 (SCC demo)	Art. 9
☐	Identities are least-privilege; no standing `pods/exec` or `get secrets` for app code or developers	Step 3 (RBAC demo)	Art. 9
☐	Two or more replicas, probes, PodDisruptionBudget, graceful shutdown	Steps 1, 3	Art. 11 (response and recovery)
☐	Images are scanned for CVEs in the pipeline before push or promotion	Step 4	Art. 9 (patches and updates), Art. 25 (vulnerability scans)
☐	SBOM (SPDX) emitted per image as a CI artifact	Step 4	Art. 8 (ICT assets and dependencies)
☐	Enforced build- and deploy-time policy gates fail the pipeline	Step 4	Art. 9
☐	No secrets in images or Git; secrets referenced from a vault and rotated without redeploy	Step 5	Art. 9
☐	The vault and operator are known third-party dependencies with an exit path	Step 5	Art. 28 (and Art. 30 for contracts, handled by procurement, legal and ICT risk, not by developers)
☐	Default-deny network policies; internal applications have no Route and accept only named callers	Step 6	Art. 9
☐	Production behavior is observed through collected logs, not shell access	Steps 1, 3	Art. 10, Art. 17 (incident management)

Three things to do on Monday

- Add the Step 4 gate to one pipeline as a report-only job for two weeks, then turn on enforcement.
- Ask the platform team which NetworkPolicy and vault integration already exist for your projects.
- Ask about image signature verification on the registry.

Developer-side working mapping to the Digital Operational Resilience Act (Regulation (EU) 2022/2554, applicable since 17 January 2025). Not legal advice and not a compliance assessment: verify each row against the Regulation text (eur-lex.europa.eu/eli/reg/2022/2554/oj), Delegated Regulation (EU) 2024/1774 and your supervisor's guidance. Full course: demon86rm.github.io/container-security-best-practices